

SIMATS ENGINEERING

ASSESSMENT TOOL III – Penetration testing Task

Course : Ethical Hacking	Code:ITA1401	CO: CO3
Duration: 90 min	Total Marks: 50	Reg No : 192521038 Name : Kalpana J

COURSE OUTCOME COVERED

CO3: *Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.(BL4)*

Duration: 90 min

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the **theHarvester** tool against the authorized domain **tesla.com**, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases. **Required Tool: theHarvester.**

Objective :

To perform passive reconnaissance on the authorized domain **tesla.com** using theHarvester and identify publicly available hosts, subdomains, IP addresses, email addresses, and other infrastructure information.

Tool Used

- **Tool:** theHarvester
- **Version:** 4.8.2
- **Target:** tesla.com
- **Type:** Passive Reconnaissance / OSINT

Command Help and Tool Options

First, theHarvester help command was used to understand the available options and search sources.

Command Used : theHarvester -h

A screenshot of a terminal window showing the output of the 'theHarvester -h' command. The output includes a title 'theHarvester', version '1.0.1', author 'Christian Martello', and a list of options: -d (domain), -b (search engine), -p (proxy), -e (email), -i (ip), -s (source), -l (limit), -o (output), -v (verbose), -h (help). It also lists search engines: google, bing, yahoo, etc. The terminal has a dark background with light-colored text.

Observation

The help output shows that theHarvester can collect publicly available information such as hosts, IP addresses, email addresses, people, and other domain-related information using different search sources.

Reconnaissance Using DuckDuckGo

The first passive reconnaissance search was performed using DuckDuckGo with a limit of 100 results.

Command Used : theHarvester -d tesla.com -b duckduckgo -l 100

Where:

- -d tesla.com : Specifies the target domain.
- -b duckduckgo : Uses DuckDuckGo as the search source.
- -l 100 : Limits the number of search results.

```
theHarvester -d tesla.com -b duckduckgo -l 100
Read all from path /etc/ssl/certs/ca-certificates.crt
=====
theHarvester 3.0.1
Created by Christian Martello
Repo: https://github.com/
theHarvester -d tesla.com -b duckduckgo -l 100
=====

[+] Target: tesla.com
[+] Searching DuckDuckGo...
[+] No IP found.
[+] No email found.
[+] No social found.
[+] No source found.

[+] Hosts Found: 4
2fdigitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

[+] Summary:
=====
theHarvester -d tesla.com -b bing -l 100
Read all from path /etc/ssl/certs/ca-certificates.crt
=====
theHarvester 3.0.1
Created by Christian Martello
Repo: https://github.com/
theHarvester -d tesla.com -b bing -l 100
=====

[+] Target: tesla.com
```

Observation

The DuckDuckGo search identified **4 hosts**:

1. 2fdigitalassets.tesla.com
2. 2fir.tesla.com
3. digitalassets.tesla.com
4. ir.tesla.com

Reconnaissance Using Bing

A second passive search was performed using Bing.

Command Used : theHarvester -d tesla.com -b bing -l 100

```
theHarvester -d tesla.com -b bing -l 100
Read all from path /etc/ssl/certs/ca-certificates.crt
=====
theHarvester 3.0.1
Created by Christian Martello
Repo: https://github.com/
theHarvester -d tesla.com -b bing -l 100
=====

[+] Target: tesla.com
[+] Searching Bing...
[+] No IP found.
[+] No email found.
[+] No social found.
[+] No source found.

[+] Hosts Found: 1
shop.tesla.com

[+] Summary:
=====
theHarvester -d tesla.com -b bing -l 100
Read all from path /etc/ssl/certs/ca-certificates.crt
=====
theHarvester 3.0.1
Created by Christian Martello
Repo: https://github.com/
theHarvester -d tesla.com -b bing -l 100
=====

[+] Target: tesla.com
An exception has occurred: SSL: no appropriate auth chain for https://104.001.143.143:https/
[+] Searching Bing...
[+] No IP found.
[+] No email found.
[+] No social found.
[+] No source found.
```

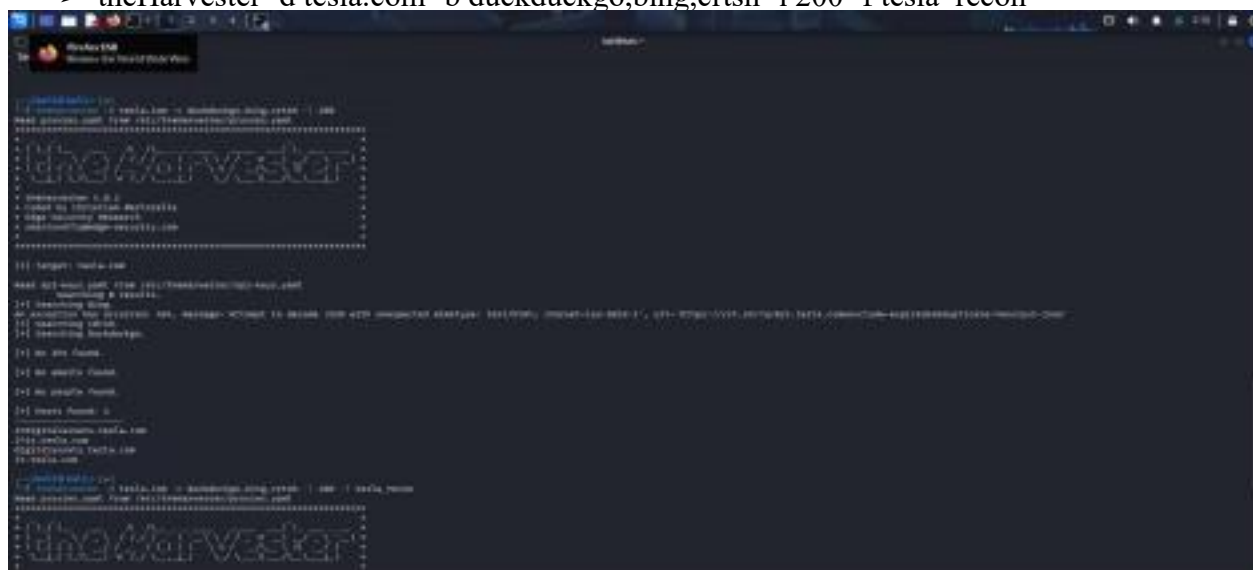
Observation

- The Bing search identified **1 host** : shop.tesla.com
- No IP addresses, email addresses, or people were found.

Combined Search Using Multiple Sources

To obtain broader passive reconnaissance results, multiple sources were searched together. **Commands Used :**

- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla recon



```
theHarvester
theHarvester 3.0.2
Control by Sebastian Muehle
Github: https://github.com
www.github.com/sebmu
www.github.com/sebmu

[+] Target: tesla.com
Hosts: 4 hosts found. From https://theharvester.com/hosts/4-hosts.html
Searching 4 results.
[+] Searching Bing.
[+] Searching DuckDuckGo.
[+] Searching crt.sh.
[+] No IP found.
[+] No email found.
[+] No results found.
[+] Hosts Found: 4
digitalassets.tesla.com
www.tesla.com
signalassets.tesla.com
cd.tesla.com

[+] Searching crt.sh.
[+] No results found.
[+] Hosts Found: 0
```

Observation : The combined search produced the following results:

- **IPs found:** 0
- **Emails found:** 0
- **People found:** 0
- **Hosts found:** 4



```
theHarvester
theHarvester 3.0.2
Control by Sebastian Muehle
Github: https://github.com
www.github.com/sebmu
www.github.com/sebmu

[+] Target: tesla.com
Hosts: 4 hosts found. From https://theharvester.com/hosts/4-hosts.html
Searching 4 results.
[+] Searching Bing.
[+] Searching DuckDuckGo.
[+] Searching crt.sh.
[+] No IP found.
[+] No email found.
[+] No results found.
[+] Hosts Found: 4
digitalassets.tesla.com
www.tesla.com
signalassets.tesla.com
cd.tesla.com

[+] Searching crt.sh.
[+] No results found.
[+] Hosts Found: 0
```

Security Analysis

- The reconnaissance identified **5 hostnames** across the DuckDuckGo and Bing searches.
- No IP addresses or email addresses were identified in the selected search results.
- No direct employee-information exposure was identified during this exercise.
- The results alone do **not** prove that any of the discovered hosts are vulnerable.
- The crt.sh source

could not be successfully queried because it returned HTTP errors.

Risk and Recommendations

- Unused or unnecessary subdomains should be removed.
- Organizations should maintain an updated inventory of externally exposed assets.
- Publicly accessible hostnames should be reviewed regularly.
- Unnecessary information disclosure should be minimized.
- Externally accessible services should be checked during authorized security testing.

Conclusion

TheHarvester was successfully used to perform passive reconnaissance on tesla.com. The assessment identified 5 publicly visible hostnames from the available search results. No IP addresses, email addresses, or people were identified.

The crt.sh source returned HTTP errors and therefore did not provide usable results during the assessment. The final reconnaissance was successfully saved in XML and JSON formats for further analysis.

2. During a penetration-testing engagement, assess the publicly accessible web application **testphp.vulnweb.com** using the **Nikto** tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. **Required Tool: Nikto.**

Objective:

To assess an authorized vulnerable web server using Nikto and identify outdated software, information disclosure, missing security headers, and configuration weaknesses.

Target: 192.168.56.102 - Metasploitable 2

Tool: Nikto 2.5.0

Protocol: HTTP/80

Commands Used

- `ping -c 4 192.168.56.102`
- `curl -I http://192.168.56.102`
- `nikto -h http://192.168.56.102`

[illegible]

```

inet addr:192.168.56.102 Bcast:192.168.56.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:2148 errors:0 dropped:0 overruns:0 frame:0
TX packets:1268 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:177874 (173.7 KB) TX bytes:92200 (90.0 KB)
Base address:0xd020 Memory:f0200000-f0220000

msfadmin@metasploitable:~$ ping -c 192.168.56.101
Usage: ping [-LRubdfnqrvUaa] [-c count] [-i interval] [-w deadline]
          [-p pattern] [-s packetsize] [-t ttl] [-I interface or address]
          [-M mtu discovery hint] [-S sndbuf]
          [-T timestamp option] [-Q tos] [hop1 ...] destination
msfadmin@metasploitable:~$ ping -c 4 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=2.20 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=1.41 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=245 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=1.99 ms

--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3002ms
rtt min/avg/max/ndev = 1.410/62.830/245.713/105.587 ms
msfadmin@metasploitable:~$
```

Findings

- Apache/2.2.8 detected - outdated component (High).
- PHP/5.2.4 detected - outdated component (High).
- Apache and PHP versions are disclosed (Medium).
- X-Frame Options is missing (Medium).
- X-Content Type Options is missing (Low - Medium).
- Apache MultiViews is enabled (Medium).
- Uncommon tcn header detected (Manual validation required).

Recommendations

Upgrade Apache and PHP, hide unnecessary version information, configure security headers, disable MultiViews if unnecessary, and investigate unusual headers. Re-run Nikto after remediation.

Conclusion:

Nikto successfully identified multiple security weaknesses in the authorized Metasploitable web server, with outdated Apache and PHP being the highest-priority issues.

3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the **Dig** utility against the authorized target domain **zonetransfer.me**, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. **Required Tool: Dig.**

Objective

To perform DNS enumeration of the authorized domain zonetransfer.me using the Dig utility, identify available DNS records and authoritative name servers, and determine whether an unauthorized DNS zone transfer (AXFR) is permitted.

Tool Used

Tool : Dig

Target : zonetransfer.me

Platform : Kali Linux

Procedure

1. The following DNS queries were performed:

- dig zonetransfer.me
- dig zonetransfer.me NS
- dig zonetransfer.me SOA
- dig zonetransfer.me A
- dig zonetransfer.me AAAA
- dig zonetransfer.me MX
- dig zonetransfer.me CNAME
- dig zonetransfer.me TXT



2. The authoritative servers were then tested for zone transfer:

- dig AXFR zonetransfer.me @nsztl.digi.ninja
- dig AXFR zonetransfer.me @nsztm2.digi.ninja





Results

1. The authoritative DNS servers identified through the successful zone transfer were:
 - nsztm1.digi.ninja
 - nsztm2.digi.ninja
2. The AXFR request to the first server successfully returned 52 DNS records. The second authoritative server also successfully returned 52 records.

Security Analysis

The successful AXFR demonstrates that an external requester could obtain a large amount of DNS information in a single operation. The information can assist reconnaissance by revealing:

- Server IP addresses
- Mail infrastructure
- Host naming conventions
- VPN-related hosts
- Office infrastructure
- Internal DNS names.

Recommendations

- Restrict AXFR/IXFR to authorized secondary DNS servers.
- Use TSIG or another suitable authentication mechanism for zone transfers.
- Prevent unauthorized external systems from requesting zone transfers.

- Separate internal and external DNS information.
- Remove obsolete and unnecessary DNS records.
- Monitor and log unexpected AXFR requests.

Conclusion

The DNS assessment successfully identified the authoritative servers and demonstrated that AXFR was permitted from both tested servers. Each server returned 52 records, exposing various hostnames, IP addresses, mail infrastructure and service-related information. The assessment demonstrates the reconnaissance risk associated with unrestricted DNS zone transfers and highlights the importance of restricting AXFR access to trusted DNS infrastructure.

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target **192.168.1.100** using **Enum4linux** to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation. **Required Tool: Enum4linux.**

Objective :

To perform authorized enumeration of a Windows SMB target using Enum4linux and identify users, groups, shared resources, workgroup information, NetBIOS details, password-policy information, and exposed SMB configuration details.

Target and Tools

Target : 192.168.56.102

Tester : Kali Linux

Required tool : Enum4linux v0.9.1

Supporting tools : Nmap, smbclient

Network : Isolated VirtualBox Host-Only network

Commands Used

- nmap -Pn -p 139,445 192.168.56.102
- enum4linux -a 192.168.56.102
- enum4linux -U 192.168.56.102
- enum4linux -G 192.168.56.102
- enum4linux -S 192.168.56.102



SMB Port Findings

1. Nmap identified :

- 139/tcp OPEN netbios-ssn
- 445/tcp OPEN microsoft-ds

2. Workgroup and NetBIOS Findings

Enum4linux identified:

- <20> - File Server Service
- <00> - Workstation Service

These details were successfully obtained through NetBIOS enumeration.

3. Anonymous/Null-Session Testing

Enum4linux attempted to establish an unauthenticated session using an empty username and password. The target rejected the request:

- Server doesn't allow session using username ", password ".
- The same restriction prevented anonymous user, group, and share enumeration.
- Assessment: Anonymous/null-session enumeration was not permitted.

4. Authenticated SMB Share Enumeration

- Using the authorized Windows account, the following shares were identified:
- These shares were returned after successful authenticated SMB access.

5. Windows Account Findings

- The local accounts identified during the assessment were : Administrator , DefaultAccount ➤ This means compromise of that account could potentially provide administrative control of the workstation.

Security Analysis

- From an attacker's perspective, the collected information provides useful reconnaissance: ➤ SMB availability identifies a Windows system offering file-sharing services. ➤ NetBIOS and workgroup information helps identify the host and its network role. ➤ Local account information provides potential username targets.
- Administrative group membership identifies a highly privileged account. ➤ SMB administrative shares may become valuable if valid credentials are compromised. ➤ Weak password-policy settings can increase the risk of credential attacks.

Recommendations

- Restrict SMB access using host/network firewall rules.
- Disable unnecessary SMB services and legacy SMB1.
- Maintain strict share and NTFS permissions.
- Review local administrator memberships and remove unnecessary accounts.
- Enforce a strong minimum password length.
- Enable appropriate password history.

Conclusion

The assessment successfully demonstrated SMB and NetBIOS enumeration against the authorized Windows target. SMB ports 139 and 445 were accessible, and WORKGROUP, JAHNAVI, and standard administrative SMB shares were identified. Anonymous/null-session enumeration was

correctly blocked. Authenticated enumeration exposed administrative shares and confirmed privileged local-account membership. The primary security improvements are stronger password controls, least-privilege administration, SMB exposure restrictions, and continued Windows patching.

5. During an external penetration-testing engagement, assess the authorized target **scanme.nmap.org** using **Netcat (nc)** to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. **Required Tool: Netcat (nc).**

Netcat External Service Assessment

Objective :

To assess the authorized target scanme.nmap.org using Netcat and identify accessible TCP services, banners, software versions, and security-relevant information disclosure.

Domain: scanme.nmap.org

IP: 45.33.32.156

Tool: Netcat (nc)

Platform: Kali Linux

Commands Used

- ping -c 4 scanme.nmap.org
- nc -vz scanme.nmap.org 22
- nc -v 45.33.32.156 22
- nc -vz scanme.nmap.org 80
- nc -v 45.33.32.156 80
- nc -vz scanme.nmap.org 53

- ```
➤ nc -v 45.33.32.156 9929
```



## Observations

- Target IP: 45.33.32.156
- Ping: 4/4 received, 0% packet loss
- 22/TCP: Open - SSH
- SSH banner: OpenSSH\_6.6.1p1 Ubuntu-2ubuntu2.13
- 80/TCP: Open - HTTP
- HTTP banner: Apache/2.4.7 (Ubuntu)
- 53/TCP: Connection refused
- 9929/TCP: Open - binary response, service not identified

**Banner:**

SSH-2.0-OpenSSH 6.6.1p1 Ubuntu-2ubuntu2.13

This reveals the SSH protocol, OpenSSH version, and Ubuntu platform information. It assists attacker fingerprinting and vulnerability research. This is primarily an information disclosure, not proof of a vulnerability. The actual installed package and patch status should be validated.

### **HTTP Finding :**

Response included:

- HTTP/1.1 400 Bad Request
- Server: Apache/2.4.7 (Ubuntu)
- Content-Type: text/html; charset=iso-8859-1
- The server reveals Apache version and Ubuntu information. This assists fingerprinting and vulnerability research. The 400 response itself is not a vulnerability.

### **TCP/9929**

- The port was open and returned binary/non-printable data. Netcat could not identify the service or version. Further authorized validation is required.

### **Remediation**

- Keep Internet-facing software patched.
- Restrict unnecessary services.
- Restrict SSH access where possible.
- Minimize unnecessary version/banner disclosure.
- Monitor externally exposed ports.
- Periodically reassess the external attack surface.

### **Conclusion**

Netcat successfully identified accessible TCP services and useful service-banner information. SSH and HTTP exposed software/version information that could assist attacker fingerprinting. These findings should primarily be treated as information disclosure, with further validation required to establish actual vulnerabilities.

### **Code of Conduct:**

I G.Harshitha - 192372384 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

**Signature of the student: Kalpana J**

**RUBRICS FOR CALCULATION:**

| <b>Criteria</b>                 | <b>Weightage</b> | <b>Level 4 – Exemplary</b> | <b>Level 3 – Proficient</b> | <b>Level 2 – Developing</b> | <b>Level 1 – Beginning</b> |
|---------------------------------|------------------|----------------------------|-----------------------------|-----------------------------|----------------------------|
| Understanding of Task           | 20               |                            |                             |                             |                            |
| Procedure & Execution           | 25               |                            |                             |                             |                            |
| Observation & Result            | 20               |                            |                             |                             |                            |
| Viva Voce / Conceptual Response | 20               |                            |                             |                             |                            |
| Time Management & Presentation  | 15               |                            |                             |                             |                            |

| <b>Criteria</b> | <b>Understanding of Task</b> | <b>Procedure &amp; Execution</b> | <b>Observation &amp; Result</b> | <b>Viva Voce / Conceptual Response</b> | <b>Time Management &amp; Presentation</b> |
|-----------------|------------------------------|----------------------------------|---------------------------------|----------------------------------------|-------------------------------------------|
| Weightage       | 20<br>(2)                    | 25<br>(3)                        | 20<br>(2)                       | 20<br>(2)                              | 15<br>(1)                                 |
| Q1              |                              |                                  |                                 |                                        |                                           |
| Q2              |                              |                                  |                                 |                                        |                                           |
| Q3              |                              |                                  |                                 |                                        |                                           |
| Q4              |                              |                                  |                                 |                                        |                                           |
| Q5              |                              |                                  |                                 |                                        |                                           |